and inspect it to retrieve data (claims) about the user. Finally, it will establish an authenticated session with the user's browser based on a session cookie, whose identifier is mapped to the JWT.

To delegate authentication and retrieve tokens securely, Edge Service must be registered as an OAuth2 Client in Keycloak. Let's see how.

11.3.3 Registering an application in Keycloak

As you learned in the previous sections, an OAuth2 Client is an application that can request user authentication and ultimately receive tokens from an Authorization Server. In the Polar Bookshop architecture, this role is played by Edge Service. When using OIDC/OAuth2, you need to register each OAuth2 Client with the Authorization Server before using it for authenticating users.

Clients can be *public* or *confidential*. We register an application as a public Client if it can't keep a secret. For example, mobile applications would be registered as public Clients. On the other hand, confidential Clients are those that can keep a secret, and they are usually backend applications like Edge Service. The registration process is similar either way. The main difference is that confidential Clients are required to authenticate themselves with the Authorization Server, such as by relying on a shared secret. It's an additional protection layer we can't use for public Clients, since they have no way to store the shared secret securely.

The Client dilemma in OAuth2

The Client role can be assigned either to a frontend or a backend application. The main difference is the level of security of the solution. The Client is the entity that will receive tokens